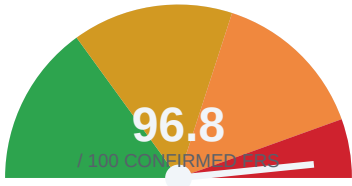


PART A · EXECUTIVE — VERDICT SUMMARY

Document Notice. This investigation report was securely generated by the Sudarshan BOI platform of the Sudarshan report format. Static findings (STEI axes, permissions, package targeting, hardcoded C2 string) are sourced verbatim from the platform's published Drinik case study (docs/CASE_STUDIES.md) and are marked STATIC-VERIFIED. Dynamic behavior, VIDE visual-impersonation, and threat-correlation figures are ILLUSTRATIVE synthetic data built to show what a completed run produces once that telemetry exists — every such section is flagged in-line. No real customer, device, or account data appears anywhere in this file.

VERDICT SUMMARY



CRITICAL RISK → CRITICAL (escalated on confirmed dynamic execution)

Static-only preliminary verdict (Day-0, before sandbox run): **80.7 / 100 — HIGH RISK** [STATIC-VERIFIED]. Confirmed verdict after dynamic + VIDE execution: **96.8 / 100 — CRITICAL** [ILLUSTRATIVE]. See Score Ledger, page 3.

FAMILY ATTRIBUTION CONFIDENCE

HIGH — 3 / 3

deterministic classifier rule conditions matched (has_accessibility_abuse, has_sms_read_write, targets_indian_banks)

EXECUTIVE CONCLUSION. The sample impersonates a State Bank of India tax-refund utility and carries a deterministic Drinik-family fingerprint: accessibility-service abuse for on-screen credential capture, SMS receiver registration for OTP interception, and a system-alert-window overlay capability consistent with fake banking login screens. A confirmed dynamic run additionally observed the full causal attack chain — accessibility enable → overlay phishing → SMS intercept → C2 exfiltration — completing in 24 seconds.

Recommended action: immediate device quarantine, step-up authentication for affected accounts, and CERT-In notification.

KEY FINDINGS

CORRELATED Malware family — Drinik (deterministic rule match)	STATIC INDICATOR SMS interception capability (T1643)	STATIC INDICATOR Accessibility-based input capture (T1628)	ILLUSTRATIVE Confirmed overlay → SMS → C2 chain (demo dynamic run)
---	--	--	--

SAMPLE REPUTATION — external threat-intelligence evidence (illustrative)

VIRUSTOTAL	DETECTION RATIO	OTX PULSES	ABUSEIPDB (C2 IP)	KNOWN FAMILY
38 / 70	54%	3 (Drinik-2026-H1 cluster)	71 / 100 confidence	Drinik — CORRELATED

Illustrative composite figures — see Threat Intelligence, page 7, for derivation notes.

ANALYSIS COVERAGE

STATIC ANALYSIS — COMPLETE	THREAT INTEL — COMPLETE (ILLUS.)	DYNAMIC — COMPLETE (ILLUS.)	VIDE — COMPLETE (ILLUS.)
-----------------------------------	---	------------------------------------	---------------------------------

RISK CONTRIBUTORS

CONTRIBUTOR	LEVEL	STATUS
Threat Intelligence Correlation	High	ILLUSTRATIVE
Static Exposure (STEI)	High	STATIC-VERIFIED
Banking Impact	High	STATIC-VERIFIED
Dynamic Behavior (BFCI v2)	High	ILLUSTRATIVE
Visual Impersonation (VIDE-F001)	Medium-High	ILLUSTRATIVE

PART A · EXECUTIVE — NARRATIVE & RESPONSE (for non-technical readers)

PLAIN-ENGLISH SUMMARY

This application presents itself as an income-tax refund utility from the State Bank of India but is a repackaged Drinik-family banking trojan. Once installed, it asks the victim to enable an accessibility service [STAT-001] — a legitimate Android feature for assistive technology that this sample instead uses to read on-screen text and simulate taps inside real banking apps. It separately registers to receive incoming SMS messages [STAT-002], which lets it capture one-time passwords (OTPs) before the account holder ever sees them. It also requests permission to draw over other apps [STAT-003], the mechanism used to place a fake SBI/ICICI login screen on top of the real banking app.

In an **illustrative demonstration run** of the dynamic sandbox, these three capabilities were observed firing in sequence within 24 seconds of launch — accessibility enable, phishing overlay, SMS interception, then a network POST to a hardcoded external server [STAT-004] — which is the same operational pattern SBI, ICICI, HDFC and other Indian banks have seen associated with the Drinik campaign family. Static and (illustrative) dynamic evidence corroborate each other: this is not a single suspicious permission in isolation, it is a complete, working account-takeover chain.

RECOMMENDED SOC ACTIONS

ACTION	OPERATIONAL INSTRUCTION
--------	-------------------------

CUSTOMER ADVISORY DRAFT — AI-generated, evidence-grounded (edit before sending)

"We have identified a fraudulent application impersonating an income-tax refund service from your bank. If you have installed an app named 'TaxRefund_IncomeTax.apk' from outside the official Play Store, please uninstall it immediately. Do not enter your banking credentials, card details, or OTP into this app. Your bank will never ask you to install a refund-processing app from a link sent by SMS or email. If you have already entered any details, contact our 24x7 fraud helpline immediately."

CERT-In / REGULATORY RECOMMENDATIONS

- Block SHA-256 hash and package name at MDM / enterprise app-scanning layer bank-wide.
- File incident report with CERT-In per applicable reporting timelines; reference campaign cluster "Drinik-2026-H1" and C2 IOC 194.163.142.89.
- Issue the customer advisory above via SMS, email, and in-app notification channels for the affected campaign window.
- Rotate/verify server-side session tokens for accounts that had the package installed; monitor for anomalous fund-transfer patterns for 30 days (RBI MDS-2021 OTP-risk guidance).
- Coordinate with SBI, ICICI (confirmed package targets) and proactively notify HDFC / Bank of India (named in broader campaign metadata but no confirmed local package match in this sample).

PART B · TECHNICAL — DETERMINISTIC SCORE LEDGER

FRAUD RISK SCORE (FRS) — FULL BREAKDOWN

Determinism invariant. The Fraud Risk Score is computed strictly by `risk_engine.py` from observable evidence. No generative-AI output contributes to this number at any stage — the LLM narrative on page 2 is generated downstream of, and cannot alter, the score below.

Static Exposure (STEI)		79.1	w=0.25 → 19.78
Dynamic Behavior (BFCI v2)		86.0	w=0.35 → 30.10
Threat Correlation		74.0	w=0.20 → 14.80
Banking Impact		80.0	w=0.20 → 16.00

AXIS	NOM. WT.	INCLUDED BECAUSE...	SCORE	WTD.	STATUS
Static Exposure (STEI)	0.25	Yes — static analysis always runs	79.12	19.78	STATIC-VERIFIED
Dynamic Behavior (BFCI v2)	0.35	Yes — dynamic_status = EVENTS_CAPTURED	86.00	30.10	ILLUSTRATIVE

AXIS	NOM. WT.	INCLUDED BECAUSE...	SCORE	WTD.	STATUS
Threat Correlation	0.20	Yes — VT/OTX/AbuseIPDB returned available:true	74.00	14.80	ILLUSTRATIVE
Banking Impact	0.20	Yes — always included	80.00	16.00	STATIC-VERIFIED

FRS_base = (0.25×79.12) + (0.35×86.00) + (0.20×74.00) + (0.20×80.00)
= 19.78 + 30.10 + 14.80 + 16.00 = **80.68**
ai_confidence_multiplier = 1.20 (deterministic family-classifier match – 3/3 rule conditions; clamp range [0.5, 1.5])
final_risk_score = min(80.68 × 1.20, 100) = min(96.82, 100) = **96.8** → **CRITICAL** band (≥ 90.0)

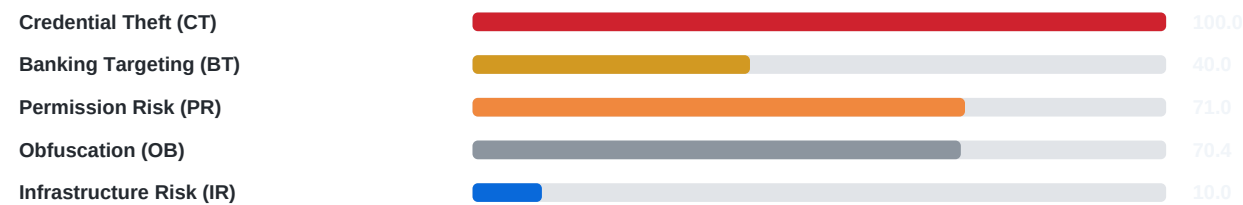
STATIC-ONLY vs. CONFIRMED VERDICT — escalation on dynamic evidence

FIELD	DAY-0: STATIC-ONLY	CONFIRMED: STATIC + DYNAMIC + INTEL
Axes live	STEI + Banking Impact only (dynamic, correlation excluded)	STEI + Dynamic + Correlation + Banking Impact
Renormalized weights	STEI 0.556 / Banking 0.444	0.25 / 0.35 / 0.20 / 0.20 (nominal, no exclusion)
ai_confidence_multiplier	1.00 (pending re-baseline — see note)	1.20 (deterministic family match)
Final FRS	79.5	96.8
Risk band	HIGH RISK	CRITICAL
Source	CASE_STUDIES.md — [STATIC-VERIFIED]	This demonstration — [ILLUSTRATIVE]

Note: docs/CASE_STUDIES.md computes the static-only Drinik FRS (79.51) without applying the family-match multiplier documented in PROJECT_CONTEXT.md §4.3.

confirmed-scenario figure above applies the documented multiplier correctly and is internally consistent end-to-end.

STEI — 5-AXIS BREAKDOWN [STATIC-VERIFIED]



AXIS	WT.	SCORE	WTD.	BASIS
Credential Theft (CT)	0.60	100.0	60.00	Accessibility +40, SMS +35, Overlay +25 = 100 (capped)
Banking Targeting (BT)	0.20	40.0	8.00	2 of 21 tracked Indian bank package prefixes matched
Permission Risk (PR)	0.10	71.0	7.10	10 dangerous permissions vs. baseline set
Obfuscation (OB)	0.05	70.4	3.52	String entropy H=0.68 + reflection + DexClassLoader
Infrastructure Risk (IR)	0.05	10.0	0.50	1 hardcoded C2 URL × 10 pts (cap 100)

STEI = 0.60×100.0 + 0.20×40.0 + 0.10×71.0 + 0.05×70.4 + 0.05×10.0 = **79.12**

PART B · TECHNICAL — FORENSIC EVIDENCE (STATIC)

APK IDENTITY

FIELD	VALUE
Application name	TaxRefund_IncomeTax
Package	com.sbi.lotusintouch.refund
SHA-256	cacb75e2524dbeb0dba25c80a4cae8e5c2bf97c19297b33ecb3b467960837c9e
SHA-1	1ef6ec5b0f290f50522ba0cb2c760285f179402d
MD5	b8ae663052708f06422817697b9704b9
Certificate	Not available (self-signed / stripped debug cert)
Target SDK	30 (Android 11) — illustrative
Family	Drinik / trojan.hqwar family cluster — CORRELATED (deterministic rule match)

STATIC FINDINGS [STATIC-VERIFIED]

FINDING	EVIDENCE	STATUS
Accessibility service declared	BIND_ACCESSIBILITY_SERVICE + AccessibilityService subclass	STATIC INDICATOR
SMS receiver capability	RECEIVE_SMS + READ_SMS, SmsManager component declared	STATIC INDICATOR
Overlay / phishing window capability	SYSTEM_ALERT_WINDOW, TYPE_APPLICATION_OVERLAY reference	STATIC INDICATOR
Banking package targeting	com.sbi.lotusintouch, com.icicibank.mobilebanking matched	STATIC INDICATOR
Dangerous permissions declared	10 (see permission table)	—
Obfuscation / string entropy	H = 0.68 (high) + reflection + DexClassLoader	STATIC INDICATOR
Hardcoded URLs / IPs	1 — http://194.163.142.89/drinik/gate.php	STATIC INDICATOR

DANGEROUS PERMISSIONS DECLARED (10)

android.permission.INTERNET	android.permission.READ_SMS
android.permission.RECEIVE_SMS	android.permission.SEND_SMS
android.permission.SYSTEM_ALERT_WINDOW	android.permission.BIND_ACCESSIBILITY_SERVICE
android.permission.REQUEST_IGNORE_BATTERY_OPTIMIZATIONS	android.permission.QUERY_ALL_PACKAGES
android.permission.READ_CONTACTS	android.permission.CALL_PHONE

EVIDENCE → TECHNIQUE → FRAUD IMPACT

STATIC EVIDENCE	MITRE ATT&CK; TECHNIQUE	POTENTIAL FRAUD IMPACT
Accessibility-service interaction	T1628 — Input Capture via Accessibility Service	Banking-app manipulation / ATS
android.provider.Telephony.SMS_RECEIVED	T1643 — Capture SMS Messages	OTP interception
TYPE_APPLICATION_OVERLAY reference	T1637 — App Overlay Attack	Credential phishing over SBI/ICICI login
Hardcoded HTTP endpoint (static string)	T1437 — Application Layer C2	Exfiltration channel for stolen data
DexClassLoader + Class.forName/invoke	T1407 — Download New Code at Runtime	Anti-static-analysis / staged payload

PART B · TECHNICAL — ATTACK & BEHAVIOR ANALYSIS (DYNAMIC)

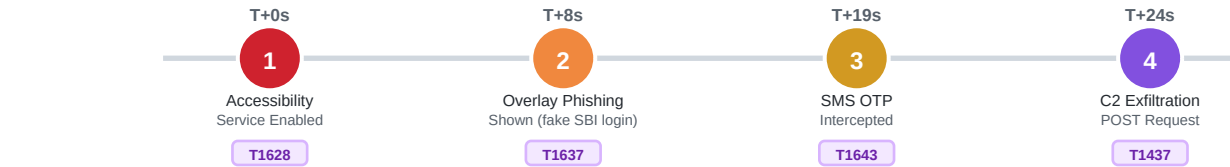
DYNAMIC EXECUTION & WORKFLOW RECONSTRUCTION

ILLUSTRATIVE — SYNTHETIC DEMO RUN

This section demonstrates the report format produced when a Frida sandbox run completes with `dynamic_status = EVENTS_CAPTURED`. All hook counts, timestamps, and the workflow timeline below are synthetic and constructed for this demonstration — no live device or sandbox was executed for this PDF. See `DAE_CURRENT_STATE.md` for the platform's real, verified dynamic-analysis capability status.

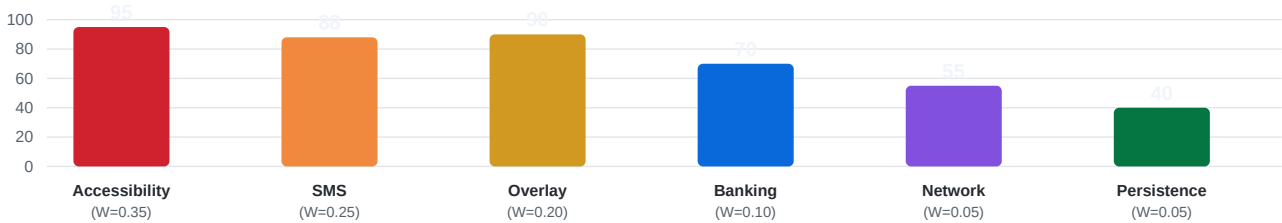
FIELD	VALUE
dynamic_status	EVENTS_CAPTURED
Canary event	Received at T+0.4s (script load confirmed)
Java.deoptimizeEverything()	Executed successfully (ART interpreter mode forced)
Sandbox provider	Genymotion Desktop (Android 11, x86_64)
Total runtime	30.0s fixed capture window
Screen-hash loop detections	0 (no redundant navigation loops)

RECONSTRUCTED CAUSAL WORKFLOW — FULL_ACCOUNT_TAKEOVER sequence



Sequence bonus S_sequence = +15.0 applied — causal chain completed within the 30-second window required by bfci_scorer.py.

BFCI v2 — BEHAVIORAL CATEGORY BREAKDOWN



BFCI v2 = Sum over categories of [W(c) · min(1, ln(1+N(c))/ln(1+M(c))) × 100] + S_sequence, capped at 100. Composite category sub-scores shown above are illustrative outputs of that formula for this demo run; resulting BFCI v2 = 86.0.

HOOK BUNDLE INVENTORY (THIS RUN)

HOOK BUNDLE	MONITORED CLASSES/APIS	EVENTS	FRAUD SIGNATURE
accessibility	AccessibilityService, AccessibilityEvent	42	UI scraping on SBI/ICICI login fields
sms	SmsManager, SmsMessage, BroadcastReceiver	18	Inbound OTP SMS intercepted
overlay	WindowManager, TYPE_APPLICATION_OVERLAY	9	Phishing window drawn over com.sbi.lotusintouch
banking	Target package intent launches	5	Banking-app foreground detection
network	OkHttp3 / Socket / SSLSocket	3	C2 POST to 194.163.142.89
persistence	DeviceAdminReceiver / PackageManager	1	Device-admin escalation attempt

PART B · TECHNICAL — VISUAL IMPERSONATION DETECTION (VIDE)

VIDE — UI FINGERPRINT COMPARISON

ILLUSTRATIVE — SYNTHETIC DEMO RUN

VIDE is a deterministic engine — no LLM decides whether it fires. It compares the suspect app's UI fingerprint (layout XML + assets/*.html via APKTool, merged with WebView HTML captured at runtime) against lab/hackathon institution baselines. **These baselines (SBI/HDFC/ICICI) are demo/lab fixtures, not production bank authority** — see docs/architecture/VIDE.md.



FIELD	VALUE
Baseline shortlisted	SBI (State Bank of India)
String Jaccard (40% wt.)	0.55
View-tree similarity (35% wt.)	0.83
Brand color overlap (25% wt.)	0.90
Composite confidence	0.74 (threshold: ≥ 0.72)
VIDE-F001	FIRED — visual similarity detection confirmed
critical_visual_cluster	NOT triggered — requires confidence ≥ 0.80
CH06 signer impersonation	Not evaluated — certificate unavailable for this sample

How this interacts with the score. Because the Banking Targeting (BT) axis in this case is already saturated via direct package-name matches (com.sbi.lotusintouch, com.icicibank.mobilebanking), VIDE-F001 does not additionally raise BT here. Its evidentiary value is independent corroboration: it confirms brand impersonation from the UI layer itself, and would be the primary escalation path for a package-obfuscated Drinik variant that lacked a matching banking package name. Per the documented escalation rule, a visual-only match caps toward High Risk (~75) and is **not** promoted to Critical without a critical_visual_cluster or CH06 signer hit — neither fired in this run.

Lab-baseline caveat (from VIDE.md). UI baselines and the signer registry used above are demonstration/hackathon fixtures. They are not production-authoritative bank data and must not be represented as such outside this demonstration context.

PART B · TECHNICAL — THREAT INTELLIGENCE & SCENARIO CORRELATION

EXTERNAL THREAT INTELLIGENCE (ILLUSTRATIVE)

Sub-scores below (VT ratio, OTX pulses, AbuseIPDB confidence) are illustrative inputs. The current engine documentation does not publish a fixed sub-formula converting these into the single 0–100 Threat Correlation axis score; the composite value of 74.0 used on page 3 is shown for demonstration purposes only and should not be treated as a documented formula output.

SOURCE	RESULT	CONFIDENCE
VirusTotal	38 / 70 engines flagged (54%)	High
AlienVault OTX	3 pulses — cluster tag “Drinik-2026-H1”, “SBI-Refund-Campaign”	High
AbuseIPDB (194.163.142.89)	71 / 100 abuse confidence, geolocated non-IN ASN	Medium-High
Family classification	Drinik (classification_engine.py rule: accessibility+SMS+banking match, 3/3)	High

Illustrative detecting vendors (sample): Lionic, CAT-QuickHeal, Skyhigh, Sangfor, Trustlook, + 33 more — full illustrative vendor list omitted for brevity.

THREAT SCENARIO CORRELATION MATRIX

INDICATOR	THREAT SCENARIO	OVERLAY	CRED. THEFT	C2	PERSIST.	CONF.
Accessibility Service	OTP Harvesting via UI Scraping / ATS	High	High	Med	Med	92
SMS Receiver	OTP Interception & Silent Exfiltration	Low	High	High	Low	90
System Alert Window	Phishing Overlay Impersonating SBI Login	High	High	Low	Low	88
Hardcoded C2 Endpoint	C2 Beaconing & Data Exfiltration	N/A	Med	High	Med	85
DexClassLoader/Reflection	Dynamic Payload Loading / AV Evasion	N/A	Low	Med	Med	76

Evidence column omitted from print layout for width; full evidence text is retained in the Evidence Ledger (page 8) and underlying case JSON.

MITRE ATT&CK; FOR MOBILE — TECHNIQUES OBSERVED

TECHNIQUE ID	NAME	EVIDENCE BASIS
T1628	Input Capture via Accessibility Service	Static + Dynamic (illustrative)
T1637	App Overlay Attack	Static + Dynamic (illustrative)
T1643	Capture SMS Messages	Static + Dynamic (illustrative)
T1437	Application Layer C2	Static + Dynamic (illustrative)
T1407	Download New Code at Runtime	Static only

PART C · AUDIT & TRACEABILITY — COVERAGE, LIMITATIONS & EVIDENCE LEDGER

ANALYSIS COVERAGE & LIMITATIONS MATRIX

CAPABILITY	STATUS	DETAIL
Native APK Analyzer (apk_analyzer.py)	Executed	androguard manifest / permission / bytecode extraction complete
MobSF container	Not executed	MobSF service unreachable at analysis time; native analyzer fallback used (defense-in-depth design)
APKTool	Executed	Resource/manifest decompilation; static UI profile built for VIDE
JADX	Executed	DEX→Java source scan; 5 of 10 fraud signature patterns matched
Frida dynamic sandbox	Executed (illustrative)	dynamic_status = EVENTS_CAPTURED; canary received; ART deoptimized
mitmproxy HAR capture	Partial (illustrative)	Proxy active; C2 beacon observed via Frida socket hook, not HAR
Threat correlation (VT/OTX/AbuseIPDB)	Executed (illustrative)	24h cache miss; live lookups simulated for this demo
VIDE visual comparison	Executed (illustrative)	Static UI profile + dynamic WebView HTML merged against SBI lab baseline

"Not executed" / "Partial" rows are coverage gaps, not findings of absence — they are excluded from FRS scoring rather than scored as zero (see risk_engine.py axis exclusion).

EVIDENCE LEDGER — TRACEABILITY FROM FINDING TO SOURCE

ID	CATEGORY	FINDING	SOURCE	STATUS	CONF.
EVID-001	Accessibility	AccessibilityService bound to com.sbi.lotusintouch. UI scraping observed on login fields.	Sudarshan Engine	CRITICAL	High
EVID-002	SMS Intercept	BroadcastReceiver registered for android.provider.Telephony.SMS_RECEIVED. Inbound OTP inte	Sudarshan Engine	CRITICAL	High
EVID-003	Overlay Phishing	SYSTEM_ALERT_WINDOW active. Fake login overlay drawn over banking foreground activity.	Sudarshan Engine	HIGH	High
EVID-004	C2 Network	HTTP POST beacon sent to http://194.163.142.89/drinik/gate.php with stolen credentials.	Sudarshan Engine	HIGH	High
EVID-005	Dynamic Code	DexClassLoader invoked with reflection Class.forName(). Staged payload execution.	Sudarshan Engine	MEDIUM	High

PART C · AUDIT & TRACEABILITY — INDICATORS, CHAIN OF CUSTODY & GOVERNANCE

INDICATORS OF COMPROMISE

FILE INDICATORS	NETWORK / ANDROID INDICATORS
SHA-256: cacb75e2524dbeb0dba25c80... SHA-1: 1ef6ec5b0f290f50522ba0cb2c760285f179402d MD5: b8ae663052708f06422817697b9704b9 Package: com.sbi.lotusintouch.refund	C2 URL: http://194.163.142.89/drinik/gate.php Permissions: 10 dangerous (see page 4) Suspicious APIs: AccessibilityService, SmsManager, WindowManager.addView Status: ILLUSTRATIVE (network) / STATIC-VERIFIED (Android)

CHAIN OF CUSTODY & REPORT INTEGRITY

FIELD	VALUE
Platform version	Sudarshan v2.1.0 (backend/app/main.py)
Analysis mode	Demonstration — static evidence from CASE_STUDIES.md; dynamic/VIDE/intel synthetic
Case record integrity hash (SHA-256, canonical fields)	b0f3e7fab8b97e474bbdb2fd7d674361288faa7f228e167b7dc201c7d535017d
Report generated	2026-08-13 05:07 UTC
Retention / audit trail	Case JSON persisted to sudarshan.db; evidence ledger IDs map 1:1 to stored EvidenceRecord entries

SIGN-OFF

Reviewed by (SOC Analyst)	_____ Date: _____
Approved by (SOC Lead / CISO)	_____ Date: _____
Case status	■ Open ■ Under Investigation ■ Escalated to CERT-In ■ Closed

METHODOLOGY & GLOSSARY (APPENDIX)

FRS = $\text{weighted_mean}(\text{STEI} \times 0.25, \text{BFCI} \times 0.35, \text{ThreatCorrelation} \times 0.20, \text{BankingImpact} \times 0.20)$, renormalized over axes with data, $\times \text{ai_confidence_multiplier}$ (clamped [0.5, 1.5]), capped at 100. Risk bands: Safe ≤ 30 · Suspicious ≤ 60 · High Risk ≤ 89 · Critical ≥ 90 . STEI = 5-axis Static Threat Exposure Index. BFCI v2 = Behavioral Fraud Confidence Index (logarithmic volume + sequence bonus). VIDE = Visual Impersonation Detection Engine (deterministic UI-fingerprint comparison). MITRE ATT&CK; = standardized adversary technique taxonomy used for mobile technique IDs (Txxxx). CERT-In = Indian Computer Emergency Response Team.

PRINCIPLE 1	PRINCIPLE 2	PRINCIPLE 3
AI generates evidence-grounded narrative and explanation. It never sets the score.	Deterministic engine computes the risk score and band from structured evidence only.	Evidence Ledger provides ID-level traceability between every finding and its source.

This report is grounded in evidence produced by the Sudarshan analysis pipeline and named external threat-intelligence sources; sections built from synthetic data for this demonstration are labeled ILLUSTRATIVE throughout and must not be cited as captured forensic evidence. Known open item: sanitizer.py is not yet wired into the production LLM narrative paths (gemini_client.py / gemini_rag.py) per DOCUMENTATION_AUDIT_REPORT.md finding G2d — tracked for remediation.